Project terminology and status

The architecture puts routing and filtering between zones on the physical HP OPNsense firewall. Windows host firewalls filter DC1 and WIN1 within Corporate. APP1's Linux host firewall filters local and overlay traffic. Apache checks separate credentials and applies manually mapped roles.

1. Access, identity, and networking

Table 1. Access, identity, and networking

Term	Meaning in this project
Zero Trust	Check identity and permission for the requested resource instead of granting access simply because a device is on a particular network. The lab studies selected principles, not full enterprise maturity.
Least privilege	Give a user, service, or device only the access required for its approved work.
Default deny	Block access unless a specific rule permits it.
Trust boundary / security zone	A boundary is where access must be checked; a zone groups components with a defined role and access policy. Being in the same zone does not grant application permission.
Management, Corporate, Restricted	The three current zones: host/firewall administration, AD/Windows endpoint, and Linux HTTPS application. Logs are reviewed from existing sources; Tailscale enrolls APP1 without an extra zone.
Hypervisor / virtual machine (VM)	The hypervisor runs separate guest operating systems on one physical host; each guest is a VM. Proxmox VE is the proposed hypervisor.
Switch / VLAN / bridge / NIC	A virtual LAN (VLAN) separates traffic on the TP-Link switch and its links. Dell Proxmox bridges connect guest network interfaces (NICs) to each zone's physical path to HP. The bridges carry no host address or routing policy.
Egress / WAN	Egress is traffic leaving a zone or the lab. The firewall's wide area network (WAN) interface is the proposed external path, disconnected until isolation is approved.
NAT	Network address translation changes packet addresses. It does not by itself prevent access to protected networks.
IPv6	Internet Protocol version 6 requires its own addressing/routing policy review so it cannot bypass the intended IPv4 boundaries.
Active Directory (AD DS) / forest / domain controller (DC)	The lab directory stores users, computers, and access groups. AD DS is the Windows directory service; a forest contains its directory domains; a DC provides domain services.
DNS / Group Policy (GPO)	The Domain Name System resolves names to service/address information. Group Policy Objects apply selected Windows configuration and access settings.
Kerberos, LDAP, SMB, RPC	Protocols used for authentication, directory access, file/policy access, and remote procedure calls. Their required flows must be scoped to approved lab components.
MFA / SSO	Multi-factor authentication checks more than one factor. Single sign-on reuses an identity provider for sign-in. Remote MFA does not automatically protect every internal logon, and corporate SSO is excluded.
Overlay / subnet router / exit node	A logical overlay runs over existing networks. Tailscale grants and device authorization limit access to APP1 TCP 443. The lab excludes subnet routers (access to other networks) and exit nodes (Internet routing).

Term	Meaning in this project
Device posture	Information about a device's security state used in an access decision. Available checks depend on the selected technology and plan; they are not assumed implemented.

2. Certificates, logging, and recovery

Table 2. Certificates, logging, and recovery

Term	Meaning in this project
PKI / CA / AD CS	Public key infrastructure manages certificate trust. A certificate authority issues certificates. This baseline uses one offline OpenSSL lab CA signing one HTTPS leaf. AD CS and a separate issuer are not required.
TLS / certificate chain	Transport Layer Security protects a connection. A chain links a service certificate to a trusted issuer/root. A trusted chain alone does not grant resource permission.
CRL / AIA / CDP	A certificate revocation list identifies revoked certificates. Authority Information Access and CRL Distribution Points tell clients where to find issuer/revocation information. These are background terms; certificate-revocation infrastructure is outside the focused baseline. App/device revocation does not prove certificate revocation.
EKU / SAN / HSM	Extended Key Usage limits certificate purpose; Subject Alternative Name identifies covered names; a hardware security module protects keys. An HSM is not part of the current lab design.
WEF / WEC / syslog / SIEM	Windows Event Forwarding sends selected events to a Windows Event Collector. Syslog carries log messages from supported systems. A security information and event management platform analyzes events; no heavyweight SIEM is assumed.
Snapshot / backup	A snapshot is a short-lived rollback aid. The recovery design requires supported encrypted backups on separate storage; a snapshot on the same disk is not that backup.
RPO / RTO	Recovery point objective limits acceptable data age after restoration. Recovery time objective limits the time to restore the agreed service scope. The focused baseline records actual backup age/recovery time and limits without enterprise RPO/RTO targets.
GiB / GB	GiB and GB use different units. The proposed VM ledger uses GiB; advertised storage capacity in GB is not the same amount of usable space.

3. Evidence, standards, and repository work

Table 3. Evidence, standards, and repository work

Term	Meaning in this project
Functional / negative test	A functional test checks a required workflow. A negative test checks that a specific unauthorized action is denied by the intended control, with a known working control case.
Independent verification / independent human review	A second observation, such as a remote Git read-back or policy log, supports verification. It is not a second human reviewer unless someone else actually reviewed the work.

Term	Meaning in this project
UAT	User acceptance testing: the owner checks whether the approved business needs are met. It stays separate from engineering tests and CI.
CI / PR / commit SHA	Continuous integration runs automated repository checks. A pull request presents branch changes for review. A commit SHA identifies a specific Git revision.
NIST / CIS / CISSP	The National Institute of Standards and Technology (NIST) and Center for Internet Security (CIS) publish reference security guidance. Certified Information Systems Security Professional (CISSP) domains provide an educational alignment. The project claims no certification, endorsed course, or full control compliance.

4. Status vocabulary

Table 4. Status vocabulary

Status	Use
PLANNED	Designed or specified; implementation evidence is not available.
IN PROGRESS	An authorized task is being carried out; unfinished steps are not complete.
IMPLEMENTED	The scoped artifact or configuration exists; the required checks may still be pending.
VALIDATED	Named checks actually passed for a stated scope and evidence cutoff. It does not imply owner acceptance.
NOT TESTED	The test was not executed or could not be verified. Historical records/tool outputs may use NOT RUN or BLOCKED; retain their original wording and explain the reason.
PASS / FAIL	The observed result met/did not meet the declared test expectation. State the evidence and scope.
PENDING owner UAT	The owner has not explicitly accepted the work. Never turn this into PASS from a CI result or engineering self-review.

Report state is separate: DRAFT means the report is being prepared; FINALIZED means its evidence record is frozen. A finalized report can still correctly contain NOT TESTED results, unresolved risks, or pending owner UAT.

5. Hardware status vocabulary

Table 5. Hardware status vocabulary

Status	Meaning
Existing	Owner reports equipment already held; suitability still needs inspection.
Ordered	Purchase/order confirmed by owner; delivery not established.
Delivered	Actual receipt recorded; installation/compatibility not implied.
Installed	Named component/software physically installed/configured with evidence; not automatically tested.
Validated	Named checks passed for the installed scope/date; owner acceptance remains separate.